



CERTIFICADOS DIGITALES AUTORIDADES DE CERTIFICACIÓN

Marcos Sánchez-Élez - Inmaculada Pardines - Eduardo Huedo

CERTIFICADO DIGITAL

- **Documento electrónico** que usa la **firma digital** de una tercera parte de confianza para **vincular una clave pública con una identidad** (persona u organización, nombre de dominio, dirección de e-mail...)
 - Compuesto por la clave pública e información identificativa adicional
- Se usa para verificar que una clave pública pertenece a un individuo, organización o servicio



CERTIFICADO DIGITAL

 Firmado y todas las firmas son válidas.

 Panel de firma



Firmas

Validar todas



Rev. 1: Firmado por PARDINES LENCE MARIA INMACULADA - DNI **<INMAPL@**

La firma es válida:
No ha habido modificaciones en: Documento desde que se firmó
Firmado por el usuario actual
La hora de la firma procede del reloj del equipo del firmante.
La firma no está activada para LTV y caducará después de 2024/10/05 12:11:47 +02'00'

 Detalles de la firma
Última comprobación: 2022.10.06 14:30:48 +02'00'
Campo: Signature1 (firma invisible)
[Haga clic para ver esta versión](#)



CERTIFICADOS DIGITALES
AUTORIDADES DE CERTIFICACIÓN

(Marcos Sánchez (Ene. Inmaculada Pardines), Educación Mundo

MODELOS DE CONFIANZA

- **Confianza jerárquica o cadena de confianza:** hay varios certificados raíz (*trust anchors*) que firman certificados finales o certificados intermedios que pueden a su vez firmar otros
 - Los certificados se verifican siguiendo la cadena de firmas hacia atrás, hasta que se encuentra un certificado raíz de confianza
 - Usada en PKI X.509
- **Red de confianza (*Web of trust*):** Se puede confiar en un certificado de forma directa o porque está firmado por otro de confianza (*trusted introducer*)
 - Usada en PGP

CONFIANZA JERÁRQUICA

- Infraestructura de clave pública PKI
- Arquitectura de una PKI
- Estructura de un certificado

INFRAESTRUCTURA DE CLAVE PÚBLICA

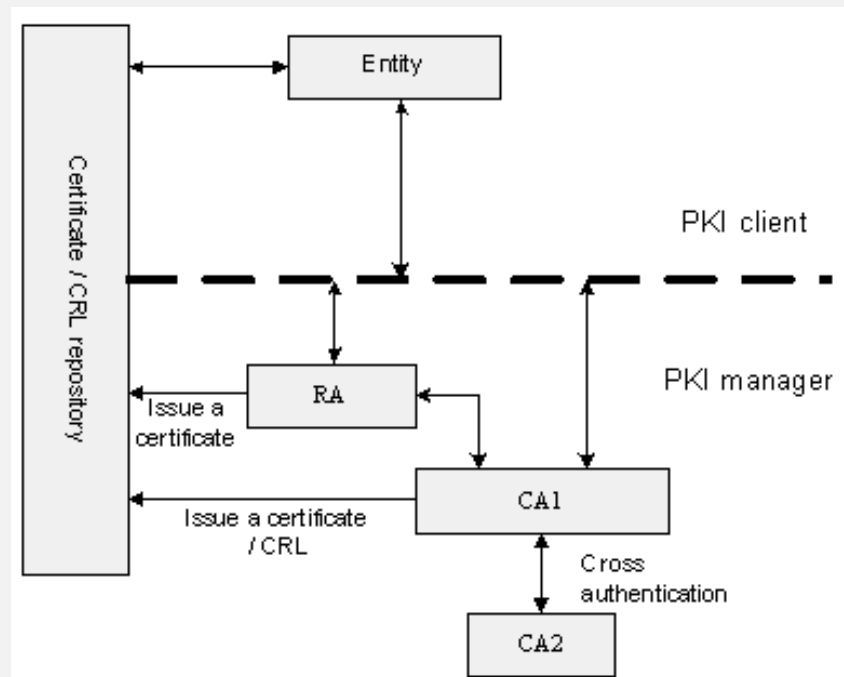
- **PKI: Public Key Infrastructure**
- PKI es una infraestructura de gestión de certificados que utiliza criptografía de clave pública y el estándar X.509 de ITU-T

“the set of hardware, software, people, policies, and procedures needed to create, manage, store, distribute, and revoke digital certificates based on asymmetric cryptography”
[RFC 4949]

- Especifica cómo crear, distribuir, mantener y revocar certificados

PKI

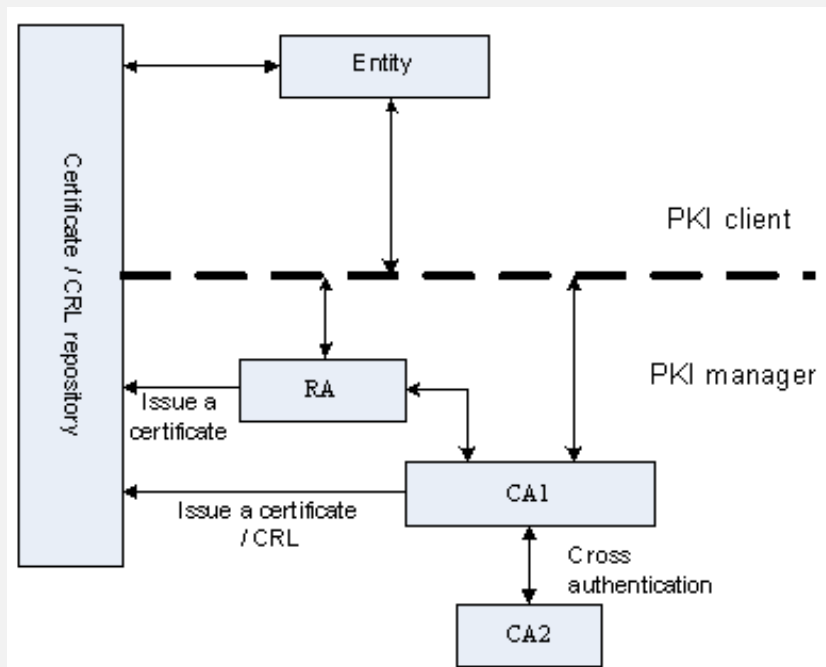
- **Autoridad de certificación (CA)**
- **Autoridad de registro (RA)**
- **Los repositorios**
- **Autoridad de validación (VA)**
- **Autoridad de sellado de tiempo (TSA)**
- **Los usuarios y entidades finales**



PKI

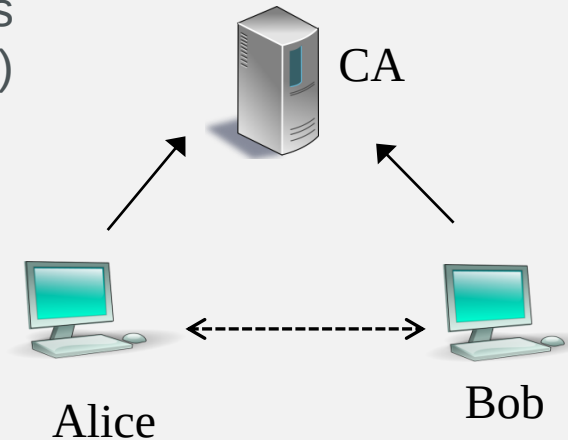
- Los componentes habituales de una PKI son:
 - **La autoridad de certificación** (CA, **Certificate Authority**): es una organización de confianza que crea, firma, mantiene y revoca certificados digitales. Es la entidad de confianza que da legitimidad a la relación de una clave pública con la identidad de un usuario o servicio.
 - **La autoridad de registro** (RA, **Registration Authority**): es una entidad que identifica de forma inequívoca al solicitante de un certificado. Suministra a la CA los datos verificados del solicitante a fin de que la CA emita el correspondiente certificado
 - **Los repositorios**: son las estructuras encargadas de almacenar la información relativa a la PKI. Los dos repositorios más importantes son el repositorio de certificados y el repositorio de listas de revocación de certificados
 - **La autoridad de validación** (VA, **Validation Authority**): es la encargada de comprobar la validez de los certificados digitales.
 - **La autoridad de sellado de tiempo** (TSA, **TimeStamp Authority**): es la encargada de firmar documentos con la finalidad de probar que existían antes de un determinado instante de tiempo.
 - **Los usuarios y entidades finales** son aquellos que poseen un par de claves (pública y privada) y un certificado asociado a su clave pública. Utilizan un conjunto de aplicaciones que hacen uso de la tecnología PKI (para validar firmas digitales, cifrar documentos para otros usuarios, etc.)

ARQUITECTURA DE UNA PKI



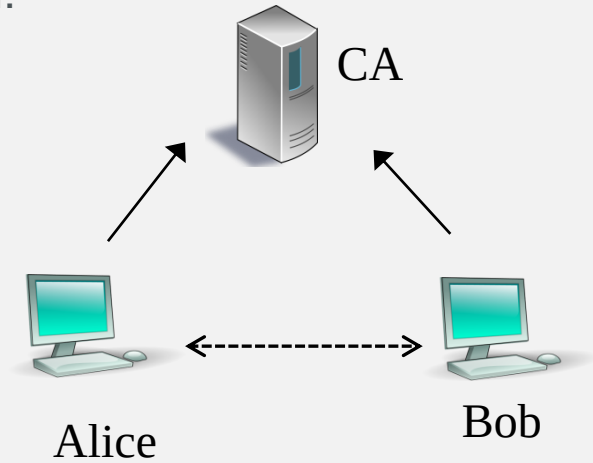
AUTORIDAD DE CERTIFICACIÓN (CA)

- La CA es una organización de confianza que crea, firma y mantiene certificados digitales
 - Equivalente digital a un estado, que emite pasaportes para los ciudadanos (equivalentes de los certificados)
 - Garantiza la identidad del usuario emitiendo los certificados asociados a él
 - Realiza el papel de *tercera parte confiable*. Unos usuarios confían en los certificados de otros porque está firmados por una CA en la que confían



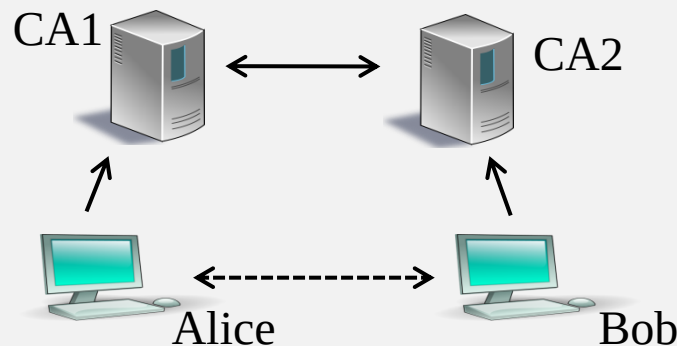
AUTORIDAD DE CERTIFICACIÓN (CA)

- Ejemplo: Alice y Bob tienen los dos un certificado emitido por la misma CA
 - Para ambos el certificado del otro será válido si:
 - ✓ Está firmado por una CA en la que **confían**
 - ✓ La firma de la CA es válida



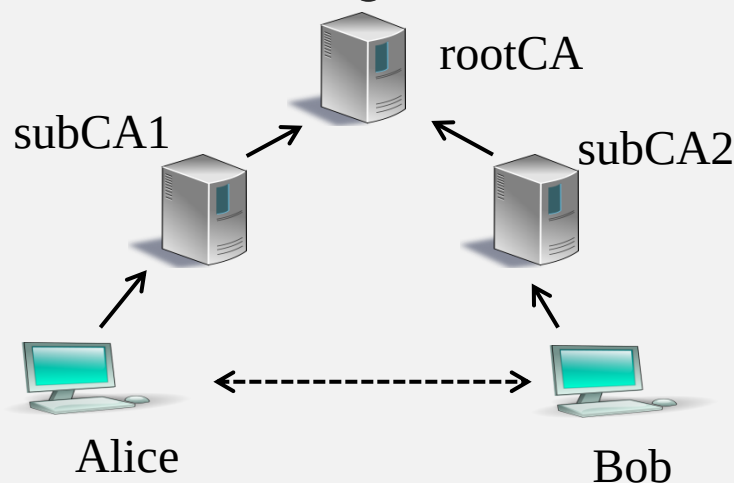
CONFIANZA ENTRE CAS

- Se puede disponer de una certificación cruzada entre dos CAs. Cada una envía su clave pública a la otra, que la firma (certificado)
- Por ejemplo, las comunicaciones entre dos organizaciones independientes



CONFIANZA ENTRE CAS

- La alternativa es una jerarquía de CAs en la que la confianza entre dos CAs se basa en la confianza en una tercera, CA raíz, que firma los certificados de cada una de ellas
- Por ejemplo, comunicaciones entre dos delegaciones de una misma organización



CONFIANZA ENTRE CAS

[mail.google.com](#)

GTS CA 1C3

Nombre del asunto

Nombre común mail.google.com

Nombre del emisor

País US
Organización Google Trust Services LLC
Nombre común [GTS CA 1C3](#)

mail.google.com

[GTS CA 1C3](#)

Nombre del asunto

País US
Organización Google Trust Services LLC
Nombre común GTS CA 1C3

Nombre del emisor

País US
Organización Google Trust Services LLC
Nombre común [GTS Root R1](#)

GTS CA 1C3

[GTS Root R1](#)

US
Google Trust Services LLC
GTS Root R1

BE
GlobalSign nv-sa
Root CA
[GlobalSign Root CA](#)

GTS CA 1C3

GTS Root R1

[GlobalSign Root CA](#)

BE
GlobalSign nv-sa
Root CA
GlobalSign Root CA

BE
GlobalSign nv-sa
Root CA
GlobalSign Root CA

¿Cuál es la jerarquía de confianza del correo electrónico de la UCM?

AUTORIDAD DE REGISTRO (RA)

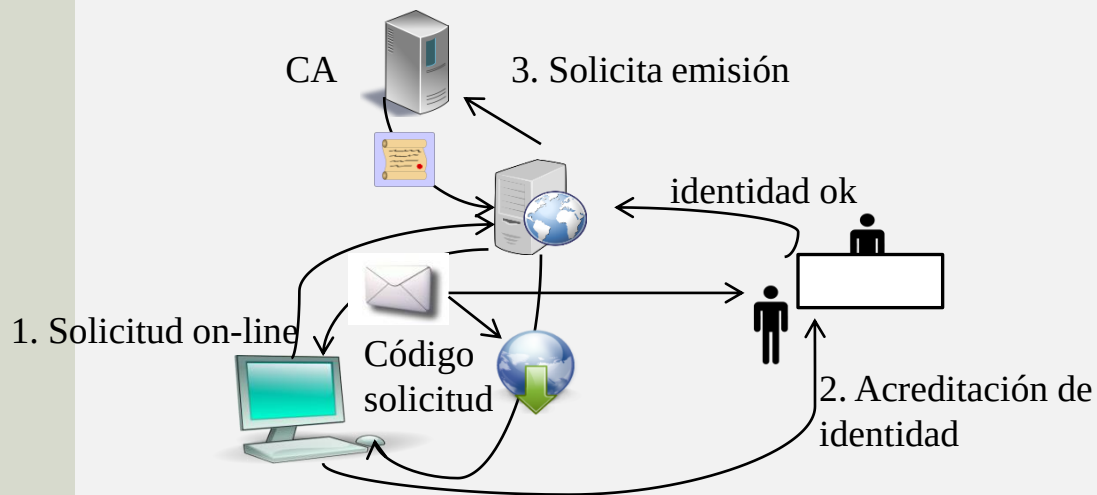
- La RA es una entidad que identifica de forma inequívoca al solicitante de un certificado. Suministra a la CA los datos verificados del solicitante a fin de que la CA emita el correspondiente certificado
 - Existen distintas formas de autenticación: presencial, telefónica, firma manuscrita
 - No es obligatorio su existencia para que el estándar PKI funcione.

SOLICITUD DE UN CERTIFICADO

■ Pasos a seguir:

1. Usuario solicita certificado a la RA
2. RA verifica la identidad del usuario y solicita la emisión del certificado a la CA
3. La CA crea y firma el certificado y lo envía al usuario

Solicitud de certificado de la FNMT



CREACIÓN DE CERTIFICADOS

■ Pasos a seguir:

1. Se genera un CSR (*Certificate Signing Request*):

```
$ openssl req -new -keyout userkey.pem -out usercsr.pem
```

- Se genera un par de claves pública y privada
- El CSR contiene la clave pública del solicitante en formato PKCS#10

2. Se verifican los datos del solicitante

- Directamente la CA o a través de una RA

3. La CA genera el certificado

```
$ openssl ca -in usercsr.pem -out usercert.pem
```

CREACIÓN DE CERTIFICADOS

Equipo local



1. Genera un par de claves

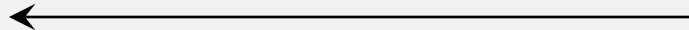
2. Envía clave pública en PKCS#10 (CSR)

CA

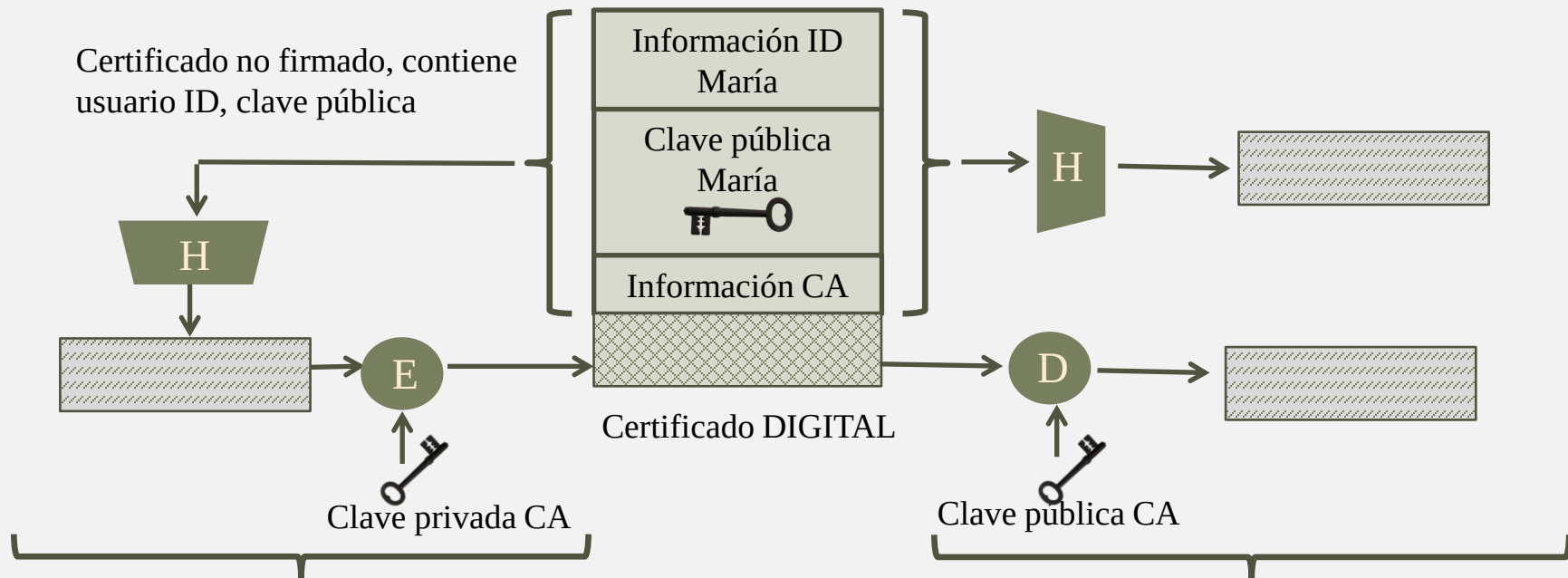


3. Firma la clave pública

4. Envía certificado X.509



CREACIÓN Y VERIFICACIÓN DE CERTIFICADOS



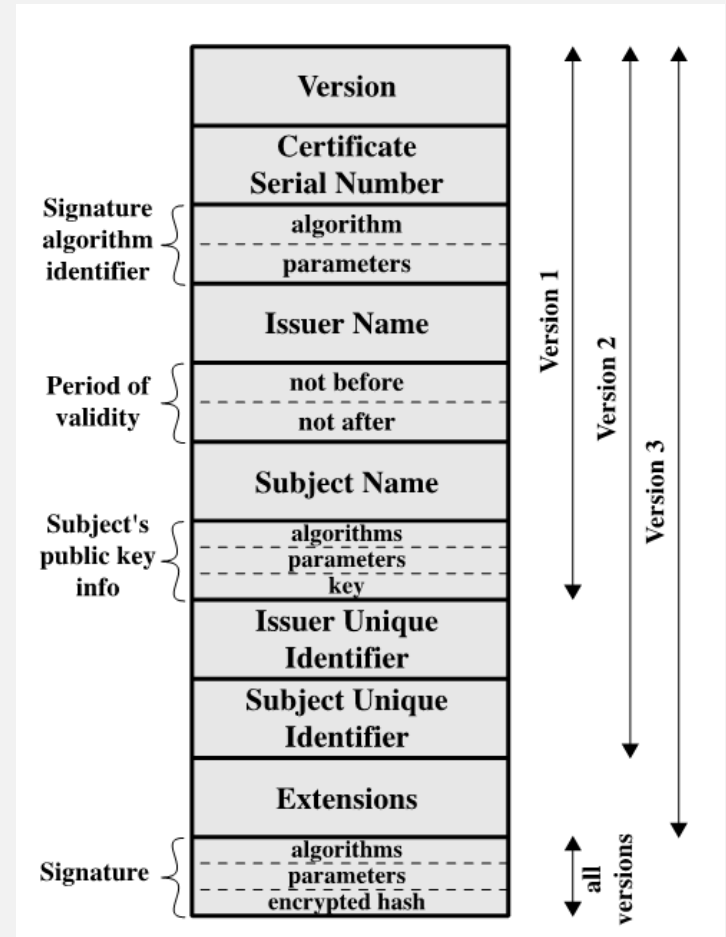
Creación del certificado FIRMADO

Módulo 2. Seguridad en las comunicaciones

Usamos la clave pública de la CA para verificar la validez del certificado de María

PK I

- Formato de un certificado X.509



X.509 CERTIFICADO DIGITAL

Certificate:

Data:

Version: 3 (0x2)
 Serial Number: 1 (0x1)
 Signature Algorithm: md5WithRSAEncryption
 Issuer: C=ZA, ST=Western Cape, L=Cape Town, O=Thawte Consulting cc,
 OU=Certification Services Division,
 CN=Thawte Server CA/Email=server-certs@thawte.com

Validity

Not Before: Aug 1 00:00:00 1996 GMT
 Not After : Dec 31 23:59:59 2020 GMT
 Subject: C=ZA, ST=Western Cape, L=Cape Town, O=Thawte Consulting cc,
 OU=Certification Services Division,
 CN=Thawte Server CA/Email=server-certs@thawte.com

Subject Public Key Info:

Public Key Algorithm: rsaEncryption
 RSA Public Key: (1024 bit)
 Modulus (1024 bit):

00:d3:a4:50:6e:c8:ff:56:6b:e6:cf:5d:b6:ea:0c:
 68:75:47:a2:aa:c2:da:84:25:fc:a8:f4:47:51:da:
 85:b5:20:74:94:86:1e:0f:75:c9:e9:08:61:f5:06:
 6d:30:6e:15:19:02:e9:52:c0:62:db:4d:99:9e:e2:
 6a:0c:44:38:cd:fe:be:e3:64:09:70:c5:fe:b1:6b:
 29:b6:2f:49:c8:3b:d4:27:04:25:10:97:2f:e7:90:
 6d:c0:28:42:99:d7:4c:43:de:c3:f5:21:6d:54:9f:
 5d:c3:58:e1:c0:e4:d9:5b:b0:b8:dc:b4:7b:df:36:
 3a:c2:b5:66:22:12:d6:87:0d

Exponent: 65537 (0x10001)

X509v3 extensions:

X509v3 Basic Constraints: critical
 CA:TRUE

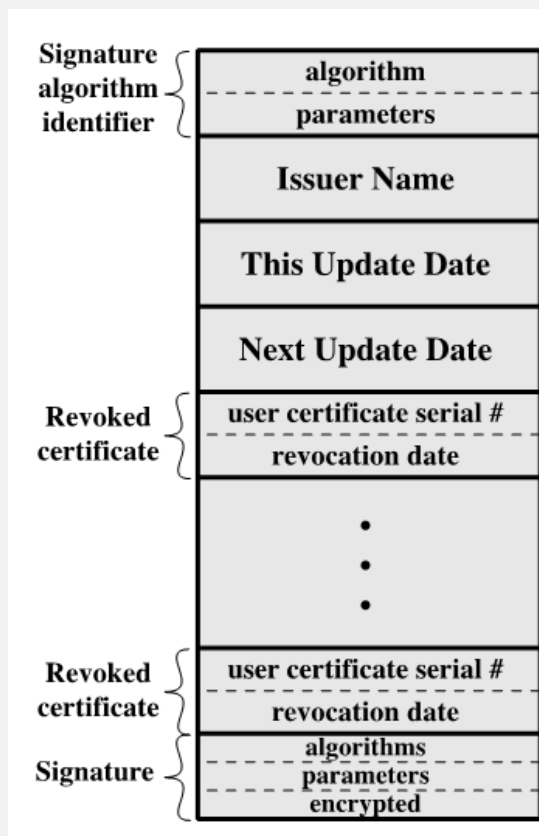
Signature Algorithm: md5WithRSAEncryption

07:fa:4c:69:5c:fb:95:cc:46:ee:85:83:4d:21:30:8e:ca:d9:
 a8:6f:49:1a:e6:da:51:e3:60:70:6c:84:61:11:a1:1a:c8:48:
 3e:59:43:7d:4f:95:3d:a1:8b:b7:0b:62:98:7a:75:8a:dd:88:
 4e:4e:9e:40:db:a8:cc:32:74:b9:6f:0d:c6:e3:b3:44:0b:d9:
 8a:6f:9a:29:9b:99:18:28:3b:d1:e3:40:28:9a:5a:3c:d5:b5:
 e7:20:1b:8b:ca:a4:ab:8d:e9:51:d9:e2:4c:2c:59:a9:da:b9:
 b2:75:1b:f6:42:f2:ef:c7:f2:18:f9:89:bc:a3:ff:8a:23:2e:
 70:47

PKI

- Formato X.509:

Formato de revocación, CRL



REVOCACIÓN DE CERTIFICADOS

- Cada certificado incluye un periodo de validez
- Sin embargo, puede ser necesario revocar un certificado antes de que expire debido a las siguientes razones:
 - Se cree que la clave privada del usuario ha sido comprometida
 - El usuario ya no está certificado por esta CA
 - ✓ El nombre de sujeto ha cambiado, el certificado ha sido sustituido, o el certificado no se emitió de conformidad con las políticas de la CA
 - Se cree que el certificado de la CA ha sido comprometido

REVOCACIÓN DE CERTIFICADOS

- En una lista de revocación de certificados (CRL, **C**ertificate **R**evocation **L**ist) se incluyen todos aquellos certificados que por algún motivo han dejado de ser válidos antes de la fecha establecida dentro del mismo certificado
- Cada CA mantiene varias CRLs (*Certificate Revocation Lists*) con todos los certificados revocados y aún no expirados emitidos por esa CA
 - Cuando se recibe un certificado, se debe comprobar que no aparezca en una de esas listas
- Las CRLs son almacenadas en servidores de acceso público (LDAP, web, ftp)
 - Cada certificado incluye la dirección en la que se puede realizar la validación

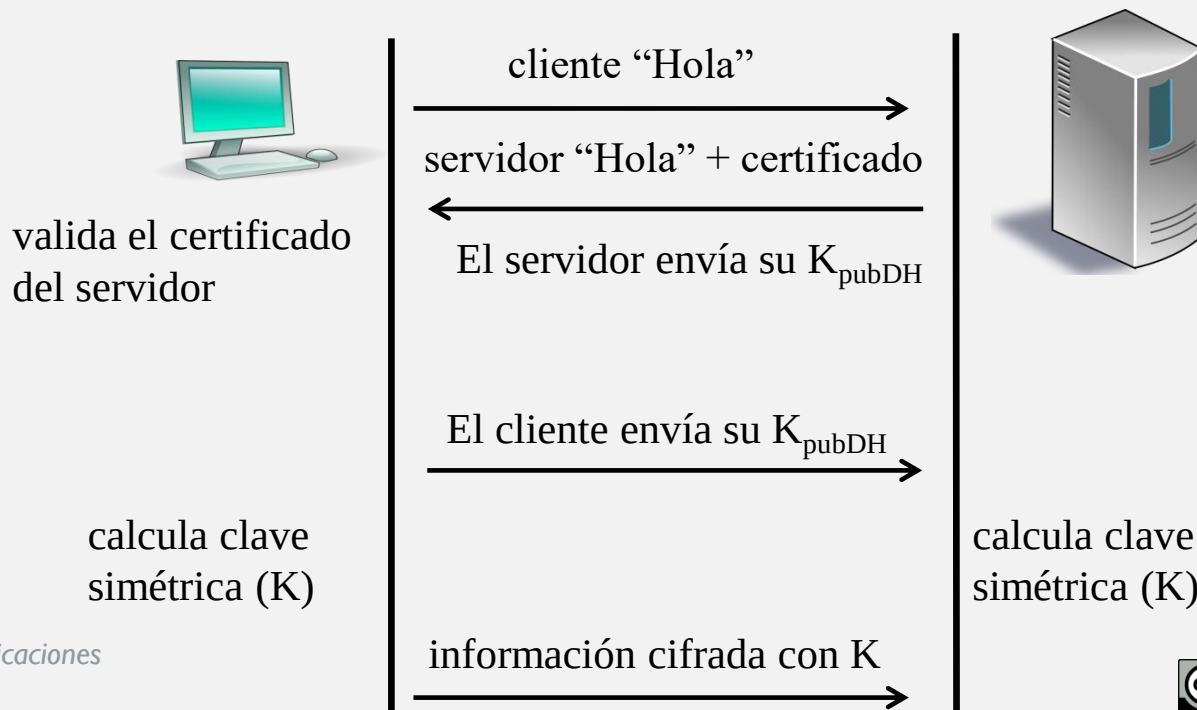
VALIDACIÓN DE CERTIFICADOS

- Localizar la CA que firmó el certificado y validar firmas
- Verificar fechas y políticas
- Comprobar si el certificado ha sido revocado. Existen dos posibilidades:
 - Consultar listas de revocación (CRL)
 - Usar el protocolo OCSP (*Online Certificate Status Protocol*)
 - ✓ Se hacen consultas a un servidor OCSP *responder* que usa un motor de base de datos para verificar el estado del certificado solicitado
 - ✓ Más moderno y eficiente
- Estas tareas las puede realizar una autoridad de validación (VA)

EJEMPLOS DE USO DE CERTIFICADOS

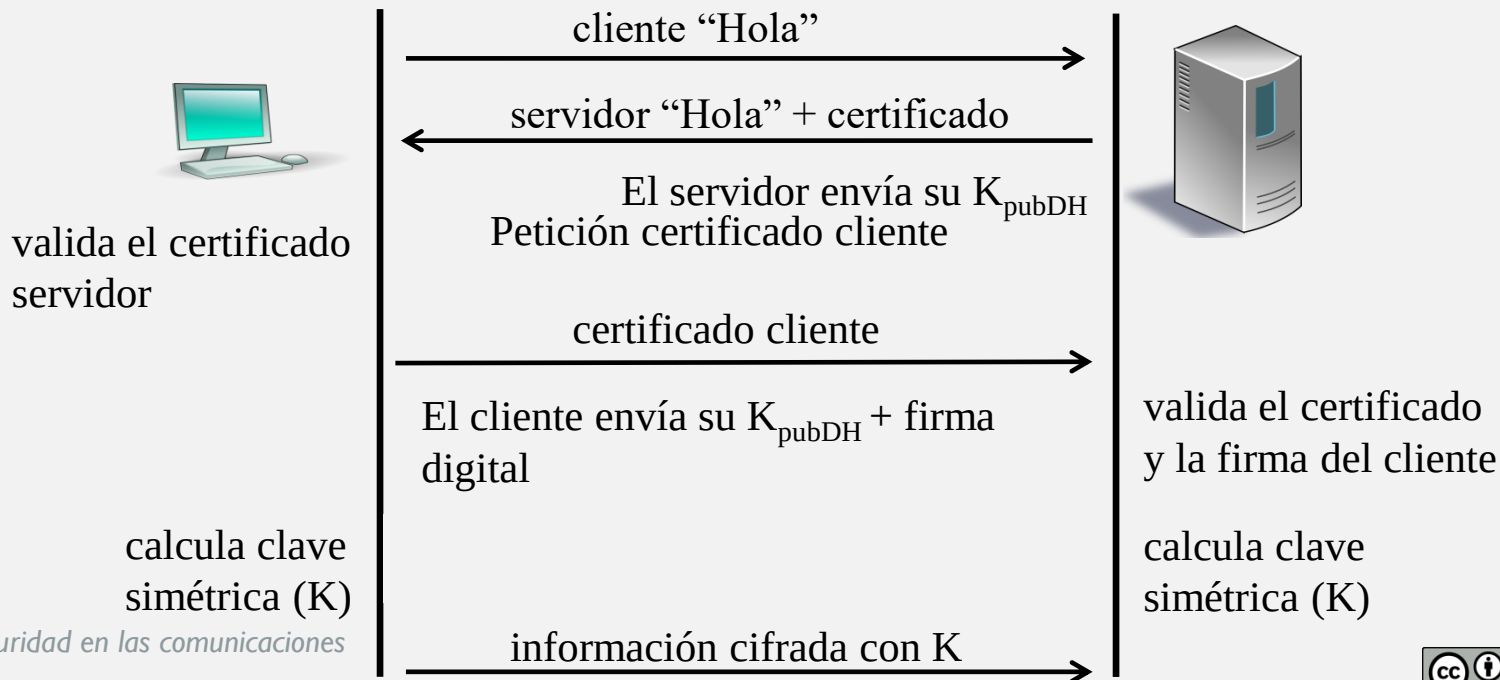
USO DE CERTIFICADOS

- Protocolo TLS para conexión con servidor (sin autenticación de cliente)



USO DE CERTIFICADOS

- Protocolo TLS para conexión con servidor (con autenticación de cliente)



RED DE CONFIANZA

PRETTY GOOD PRIVACY (PGP)

- Creado en 1991 por Phil Zimmermann
 - Renombrado después como GnuPG o GPG (*GNU Privacy Guard*)
- En 1997 se forma el grupo de trabajo sobre OpenPGP en el IETF
 - La propuesta de estándar OpenPGP [RFC 4880] es un formato no propietario para cifrar correo electrónico usando criptografía de clave pública
 - Define formatos estándar para los mensajes cifrados, firmas y certificados para intercambiar claves públicas

RED DE CONFIANZA PGP

- Modelo de confianza descentralizado
 - Hay muchas redes de confianza independientes, y un usuario puede ser parte de varias de ellas y servir de enlace entre ellas
- Planteado por primera vez en 1992, en la versión 2.0 del manual de PGP:

“As time goes on, you will accumulate keys from other people that you may want to designate as trusted introducers. Everyone else will each choose their own trusted introducers. And everyone will gradually accumulate and distribute with their key a collection of certifying signatures from other people, with the expectation that anyone receiving it will trust at least one or two of the signatures. This will cause the emergence of a decentralized fault-tolerant web of confidence for all public keys”

RED DE CONFIANZA PGP

- Los certificados son parecidos a los de X.509
 - Incluyen una auto-firma y pueden tener varias firmas de otros individuos
- Cualquier usuario puede actuar como autoridad de certificación
- A puede validar las claves de B , pero cualquier otro usuario no considerará válidas estas claves salvo que un tercer usuario C reconozca a A como fiable

VALIDEZ Y CONFIANZA EN PGP

- **Validez:** Propiedad que certifica que una clave pública pertenece al aparente propietario
 - Se **recalcula de forma automática** mediante un algoritmo
- **Confianza:** Es la creencia en la responsabilidad del dueño de una clave a la hora de firmar otras claves
 - Se basa en la percepción del dueño del anillo, que la **asigna manualmente**
- El valor de validez y confianza puede ser: desconocida, ninguna, dudosa, total o absoluta (*unknown, none, marginal, full o ultimate*)

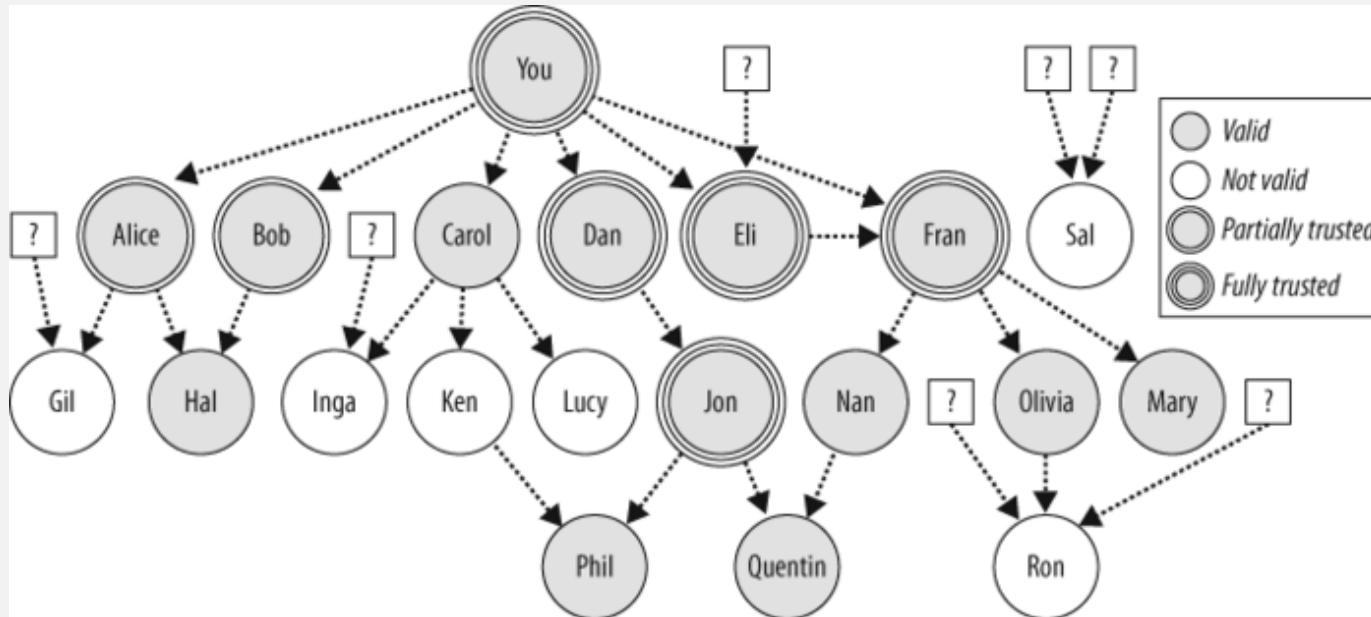
ANILLOS DE CLAVE PGP

- **Anillo público:** Almacena las claves públicas de todos los usuarios conocidos
 - Cuando un usuario incorpora una nueva clave a su anillo le asigna un nivel de confianza
 - Si la clave es del propio usuario tendrá confianza absoluta
 - Cuando un usuario firma una clave del anillo, PGP busca en el anillo al firmante
 - ✓ Si está le asigna una confianza a la firma (*sigtrust*) igual al valor de confianza del firmante en el anillo sino le asigna el valor de “desconocida”
 - La validez de las claves es recalculada cada cierto tiempo, en base a la confianza de las claves que las firman
- **Anillo privado:** Contiene la clave pública y privada del usuario

VALIDEZ DE LAS CLAVES PGP

- La **validez** de la clave se calcula a partir de la **confianza en el propietario** de las claves que la firman
- Una clave tiene **validez total** si está firmada por suficientes claves válidas, lo que significa que:
 - ✓ El dueño del anillo la ha firmado con su clave, con **confianza absoluta**
 - ✓ O ha sido firmada por **una clave con confianza total**
 - ✓ O ha sido firmada por **tres claves con confianza dudosa**

EJEMPLO DE RED DE CONFIANZA



En este ejemplo por simplificar el dibujo, solo se necesitan las firmas de dos claves con confianza dudosa para que la validez de una clave sea total

Módulo 2. Seguridad en las comunicaciones